

LAPORAN THREAT MODELING & VULNERABILITY ASSESSMENT

IPB SPACE: CAMPUS FACILITY & QUEUE SYSTEM

IDENTIFIKASI ANCAMAN DAN EVALUASI KERENTANAN ARSITEKTUR PERANGKAT LUNAK BERBASIS STRIDE



Disusun Oleh (Kelompok 4 - Paralel 1):

- | | |
|---------------------------|---------------|
| 1. Naufal Ghifari Afdhala | (G6401231029) |
| 2. Samuel Christian | (G6401231037) |
| 3. Muhammad Farhadh | (G6401231080) |

**DEPARTEMEN ILMU KOMPUTER
SEKOLAH SAINS DATA, MATEMATIKA, DAN INFORMATIKA
INSTITUT PERTANIAN BOGOR
BOGOR
2026**

INFORMASI DOKUMEN DAN METADATA MANAJEMEN RISIKO

Parameter Analisis	Spesifikasi Manajemen Risiko Perangkat Lunak
Mata Kuliah	KOM1315 Keamanan Informasi (Project-Based Learning Terintegrasi)
Nama Dokumen Luaran	Threat_Modeling.pdf (Hasil Penilaian Risiko & Assessment Awal)
Lokasi Folder Repo	/01_Proposal&Analisis/Threat_Modeling.pdf
Metodologi Pemodelan	STRIDE Framework (Spoofing, Tampering, Repudiation, Info Disclosure, DoS, EoP)
Cakupan Penilaian	Arsitektur 3-Tier, Autentikasi Sesi JWT, Enkripsi AES-256, Concurrency Guard Locking
Tautan Repositori	github.com/nghifaria/KOM1315_SmtGenap26_Kelompok04_IPBspace
Tautan Aplikasi Live	https://kom-1315-smt-genap26-kelompok04-ipb.vercel.app/
Akun Penguji Reviewer	shelvie.neyman @ gmail.com & endang.p.giri @ gmail.com

Daftar Isi

BAB 1: PENDAHULUAN	4
1.1 Latar Belakang Threat Modeling	4
1.2 Tujuan Analisis Ancaman dan Kerentanan	4
1.3 Metodologi Pengujian (STRIDE Framework)	4
BAB 2: DIAGRAM ALIRAN DATA DAN BATASAN KEAMANAN (DFD & TRUST BOUNDARIES)	6
2.1 Batasan Kepercayaan Sistem (Trust Boundaries)	6
2.2 Data Flow Diagram (DFD) Level 0 - Diagram Konteks	6
2.3 Data Flow Diagram (DFD) Level 1 - Dekomposisi Proses Inti	7
BAB 3: IDENTIFIKASI ANCAMAN BERBASIS MATRIKS STRIDE	8
3.1 Spoofing (Pemalsuan Identitas Aktor dan Sesi)	8
3.2 Tampering (Manipulasi Data Transaksi dan Berkas)	8
3.3 Repudiation (Penyangkalan Tindakan Aktivitas Birokrasi)	9
3.4 Information Disclosure (Kebocoran Informasi Privasi Civitas)	9
3.5 Denial of Service (Kelumpuhan Layanan Konkuren)	9
3.6 Elevation of Privilege (Eskalasi Hak Akses Tidak Sah)	10
BAB 4: HASIL VULNERABILITY ASSESSMENT AWAL DAN STRATEGI MITIGASI	11
4.1 Matriks Penilaian Risiko Ancaman (Risk Assessment Matrix)	11
4.2 Implementasi Solusi Defensif Sistem	12
4.2.1 Mitigasi Spoofing dan Elevation of Privilege via Protokol AAA & RBAC	12
4.2.2 Mitigasi Information Disclosure via Column-Level Encryption (AES-256)	12
4.2.3 Mitigasi Tampering dan Repudiation via Immutable Audit Trail	12
4.2.4 Mitigasi Denial of Service via Concurrency Guard	12
BAB 5: POHON SERANGAN (ATTACK TREES) DAN VEKTOR EKSPLOITASI	14
5.1 Analisis Pohon Serangan Spoofing Sesi dan Kredensial	14
5.1.1 Dekonstruksi Vektor Eksploitasi Spoofing	14
5.2 Analisis Pohon Serangan Tampering dan Modifikasi Transaksi	14
5.2.1 Dekonstruksi Vektor Eksploitasi Tampering	15
BAB 6: KERANGKA PERTAHANAN BERLAPIS DAN KESIMPULAN AUDIT	16
6.1 Pemetaan Strategi Defense-in-Depth IPB Space	16
6.1.1 Analisis Integrasi Lapis Pertahanan Siber	16
6.2 Kesimpulan Hasil Pemodelan Ancaman Siber	16

BAB 1: PENDAHULUAN

1.1 Latar Belakang Threat Modeling

Transformasi digital dalam tata kelola fasilitas kampus melalui pengembangan platform **IPB Space** secara mendasar mengubah peta risiko dan permukaan serangan (*attack surface*) sistem. Ketika prosedur birokrasi peminjaman dialihkan dari metode konvensional berbasis logbook fisik dan ruang obrolan informal menuju sistem informasi berbasis web yang terintegrasi penuh, ancaman siber yang dihadapi tidak lagi terbatas pada aspek inefisiensi administrasi, melainkan bergeser ke ranah teknis siber eksponensial.

Ketiadaan analisis ancaman sejak dini pada fase perancangan kode program dapat mengekspos arsitektur perangkat lunak terhadap berbagai kerentanan kritis yang fatal. Celah keamanan arsitektural seperti manipulasi parameter paket data HTTP, kebocoran basis data relasional dalam bentuk teks terang (*plaintext database breach*), bypass otorisasi rute fungsional, hingga kondisi balapan memori server (*race condition*) saat menangani permintaan pemesanan jadwal ganda secara bersamaan dapat melumpuhkan kredibilitas institusi. Oleh karena itu, tindakan proaktif berupa pemodelan ancaman (*threat modeling*) dan penilaian kerentanan awal (*vulnerability assessment*) ini wajib dilakukan untuk mengidentifikasi, mengisolasi, dan memitigasi celah siber sebelum sistem dideploy di lingkungan cloud produksi.

1.2 Tujuan Analisis Ancaman dan Kerentanan

Penyusunan dokumen pemodelan ancaman ini memiliki tujuan strategis yang terukur bagi Kelompok 04:

1. **Identifikasi Dini Celah Arsitektur:** Memetakan titik lemah potensial pada arsitektur tiga lapisan yang menghubungkan React 19 frontend, FastAPI backend server container, dan PostgreSQL database.
2. **Mitigasi Risiko Eksposur Data:** Melindungi kerahasiaan data pribadi civitas akademika dari ancaman pencurian data massal melalui pemodelan eksploitasi ORM.
3. **Pencegahan Malfungsi Logika Bisnis:** Menjamin ketahanan mekanisme pencegahan jadwal ganda (*double booking*) dari ancaman pemboman request konkuren.
4. **Penegakan Prinsip Security by Design:** Memastikan penempatan modul kriptografi simetris dan asimetris diletakkan sebagai komponen wajib di alur kerja utama aplikasi, bukan sebagai fitur tempelan terpisah.

1.3 Metodologi Pengujian (STRIDE Framework)

Analisis keamanan dan pemodelan ancaman pada ekosistem IPB Space dilakukan secara terstruktur mengadopsi standar industri **STRIDE Framework**. Kerangka kerja ini membagi potensi ancaman ke dalam enam kategori taksonomi keamanan:

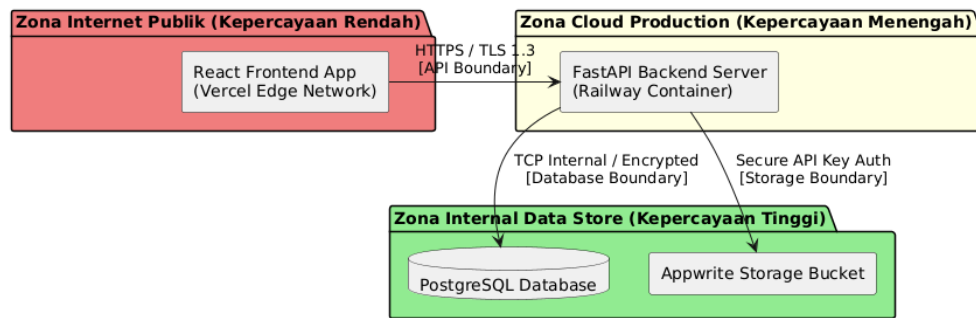
- **Spoofing (Pemalsuan Identitas):** Ancaman yang berkaitan dengan aktor ilegal yang berhasil mereplikasi token sesi JWT aktif atau memalsukan identitas kredensial civitas untuk menembus gerbang masuk sistem.
- **Tampering (Manipulasi Data):** Risiko perubahan tidak sah terhadap data transaksi reservasi di database PostgreSQL atau modifikasi konten biner dokumen proposal PDF yang tersimpan di server.
- **Repudiation (Penyangkalan Tindakan):** Celah keamanan yang terjadi jika sistem tidak mampu membuktikan validitas tindakan seorang operator, memungkinkan oknum menyangkal aktivitas pembatalan jadwal sepihak.

- **Information Disclosure (Kebocoran Informasi):** Kerentanan arsitektural REST API yang mengekspos data privasi pengguna (NIK dan Nomor HP) dalam format plaintext kepada publik akibat kegagalan enkripsi database.
- **Denial of Service (Kelumpuhan Layanan):** Serangan pemboman request massal pada milidetik yang sama yang bertujuan menghancurkan ketersediaan server FastAPI dan memicu *system crash*.
- **Elevation of Privilege (Eskalasi Hak Akses):** Celah manipulasi token klien yang memungkinkan akun peran rendah mengeksekusi endpoint administratif yang seharusnya diisolasi khusus bagi peran Super Admin.

BAB 2: DIAGRAM ALIRAN DATA DAN BATASAN KEAMANAN (DFD & TRUST BOUNDARIES)

2.1 Batasan Kepercayaan Sistem (Trust Boundaries)

Trust Boundaries mengidentifikasi parameter batas di dalam arsitektur perangkat lunak IPB Space di mana aliran data berpindah dari satu tingkat zona kepercayaan ke tingkat zona kepercayaan lainnya. Menetapkan batasan ini sangat penting untuk menaruh pos pemeriksaan validasi data secara tepat:

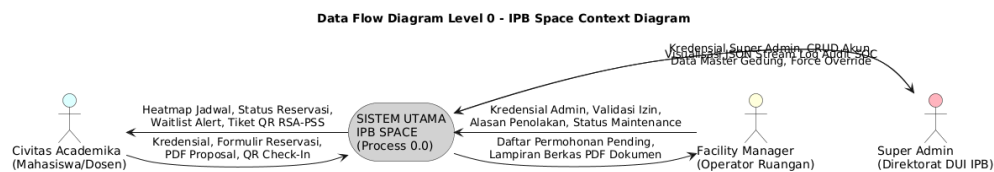


Gambar 2.1: Diagram Batasan Kepercayaan (Trust Boundaries) Sistem IPB Space.

1. **API Boundary (Client-to-Backend):** Menghubungkan browser internet publik pengguna dengan server backend FastAPI di cloud Railway. Berada di zona kepercayaan rendah, mewajibkan enkripsi jalur komunikasi **HTTPS TLS 1.3** (Data in Transit) dan intersektor token JWT Bearer.
2. **Database Boundary (Backend-to-PostgreSQL):** Berada di zona internal cloud yang memiliki kadar kepercayaan tinggi. Namun, untuk mematuhi regulasi privasi data, perpindahan data sensitif melewati batas ini wajib diubah menjadi ciphertext melalui fungsi **Column-Level Encryption (AES-256-GCM)** sebelum menyentuh disk penyimpanan database.
3. **Third-Party Storage Boundary:** Batas aliran berkas PDF menuju eksternal storage. Memerlukan isolasi ketat pada level manajemen API Key di dalam lingkungan variabel sistem operasi backend agar tidak bocor.

2.2 Data Flow Diagram (DFD) Level 0 - Diagram Konteks

Data Flow Diagram Level 0 mengisolasi platform IPB Space sebagai satu entitas proses besar yang berinteraksi secara global dengan tiga aktor luar:



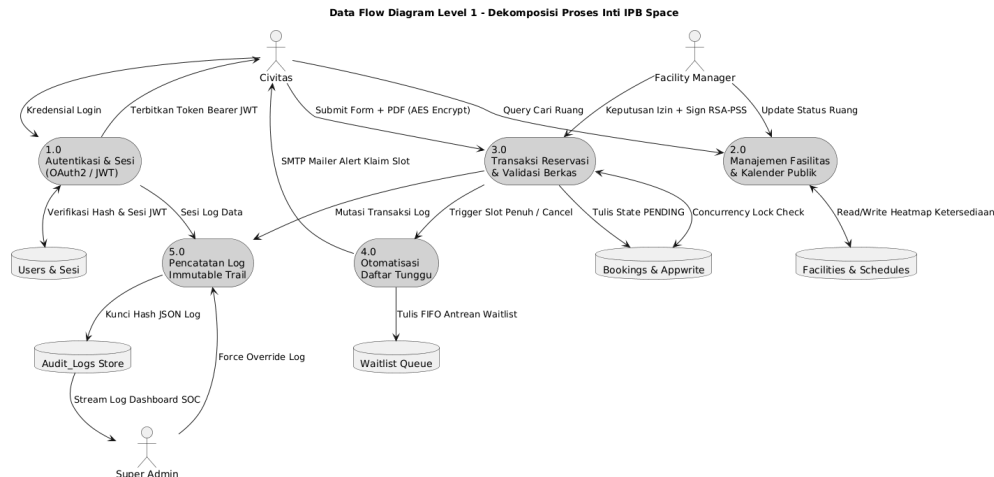
Gambar 2.2: Data Flow Diagram (DFD) Level 0 - Konteks Sistem IPB Space.

- **Aktor Civitas:** Menyuplai input kredensial otentikasi, parameter pencarian ruang, berkas digital PDF, dan request check-in. Menerima output status ketersediaan ruang, nomor antrian waitlist, dan berkas Digital Ticket terenkripsi.
- **Aktor Facility Manager:** Menyuplai keputusan validasi persetujuan izin, alasan penolakan, dan parameter penutupan maintenance ruangan. Menerima output daftar permohonan pending dan muatan berkas PDF.

- **Aktor Super Admin:** Menyuplai perintah pembuatan akun operator baru, data master prasarana fisik gedung, dan perintah intervensi jadwal darurat (*Force Override*). Menerima luaran stream objek data log siber audit forensik SOC.

2.3 Data Flow Diagram (DFD) Level 1 - Dekomposisi Proses Inti

DFD Level 1 memecah proses tunggal sistem menjadi lima sub-proses fungsional utama yang berinteraksi secara asinkron dengan media penyimpanan data relasional (**Data Stores**):



Gambar 2.3: Data Flow Diagram (DFD) Level 1 - Dekomposisi Sub-Proses Inti Keamanan IPB Space.

1. **Proses 1.0 (Autentikasi & Manajemen Sesi JWT):** Memproses kecocokan email dan biner kata sandi hash dari tabel Users, menerbitkan bearer token JWT ganda, dan menulis catatan sesi aktif ke User_Sessions store.
2. **Proses 2.0 (Manajemen Fasilitas & Kalender):** Melakukan kueri baca dan tulis secara konkuren pada tabel Facilities dan Schedules untuk menyajikan visualisasi kalender ketersediaan dinamis bebas tumpang tindih bagi civitas.
3. **Proses 3.0 (Transaksi Reservasi & Validasi Berkas):** Mengaktifkan fungsi Concurrency Guard, melakukan pelepasan berkas PDF terenkripsi ke storage, menulis state reservasi awal berkode PENDING ke tabel Bookings, serta memproses penandatanganan asimetris RSA-PSS oleh operator.
4. **Proses 4.0 (Otomatisasi Daftar Tunggu):** Terpancing secara otomatis oleh kegagalan transaksi pada Proses 3.0 akibat bentrok jadwal. Mengelola antrian data secara adil berdasarkan urutan waktu FIFO pada tabel Waitlist dan mengelola protokol SMTP mailer penawaran slot.
5. **Proses 5.0 (Pencatatan Jejak Digital Immutable):** Menangkap aliran intersektor event siber dari Proses 1.0, 3.0, dan intervensi paksa Super Admin di Proses 2.0. Mengunci seluruh metadata aktivitas ke dalam database Audit_Logs secara asinkron menggunakan skema non-blocking.

BAB 3: IDENTIFIKASI ANCAMAN BERBASIS MATRIKS STRIDE

Tahap inti dari pemodelan ancaman (*threat modeling*) adalah melakukan analisis mendalam terhadap setiap elemen aliran data dan sub-proses ekosistem IPB Space menggunakan matriks taksonomi STRIDE. Dengan memetakan setiap potensi serangan siber secara prosedural pada setiap sub-proses hasil dekomposisi DFD Level 1, tim pengembang Kelompok 04 dapat mendeteksi, mengisolasi, dan mengevaluasi kerentanan arsitektur sebelum sistem masuk ke dalam fase implementasi kode produksi cloud.

3.1 Spoofing (Pemalsuan Identitas Aktor dan Sesi)

Ancaman *Spoofing* terjadi ketika pihak luar yang tidak memiliki hak wewenang sah berhasil menduplikasi, mereplikasi, atau memalsukan identitas digital serta token sesi milik aktor lain yang valid untuk mengelabui gerbang pertahanan autentikasi sistem.

- **Target Elemen Sistem:** Proses 1.0 (Autentikasi dan Sesi JWT), Endpoint `/api/v1/auth/login`, serta Data Store: Users pada database PostgreSQL.
- **Skenario Ancaman Lengkap:** Penyerang meluncurkan serangan siber berupa *credential harvesting* melalui halaman phishing, mencoba menebak kombinasi kata sandi via metode otomatis *brute-force* masif, atau melakukan serangan *credential stuffing* menggunakan basis data kebocoran dari platform lain yang menargetkan email institusi milik Civitas (Mahasiswa/Dosen) atau Facility Manager. Jika penyerang berhasil mendapatkan kredensial teks terang tersebut, mereka dapat bertindak atas nama korban untuk melakukan pemesanan ruang palsu (*Ghost Booking*) yang merugikan utilitas kampus, atau menyalahgunakan wewenang persetujuan izin ruang untuk kepentingan sepihak. Selain itu, ancaman ini mencakup upaya intersepsi paket data untuk mereplikasi struktur *Access Token JWT* yang aktif di browser klien atau memalsukan muatan kode unik biner pada QR Code tiket digital untuk melewati pemeriksaan fisik petugas keamanan prasarana di lapangan.

3.2 Tampering (Manipulasi Data Transaksi dan Berkas)

Ancaman *Tampering* melibatkan aksi modifikasi, pengubahan, penyisipan, atau penghapusan data secara ilegal oleh aktor yang tidak berwenang, baik terhadap data yang sedang bergerak melintasi saluran internet (*Data in Transit*) maupun data diam di dalam media penyimpanan (*Data at Rest*).

- **Target Elemen Sistem:** Proses 3.0 (Transaksi Reservasi dan Validasi), Data Store: Bookings, serta Server File Storage.
- **Skenario Ancaman Lengkap:** Pengguna yang berniat curang sengaja melakukan intersepsi lalu lintas trafik HTTP request menggunakan perangkat lunak local proxy seperti *Burp Suite Professional* pada saat mengirimkan formulir pengajuan peminjaman ruangan. Penyerang mencoba memanipulasi parameter payload JSON yang dikirim ke backend FastAPI, seperti mengubah nilai variabel data status secara paksa dari format asal PENDING langsung menjadi APPROVED guna melewati jalur birokrasi peninjauan operator. Vektor serangan ini juga menyasar pada manipulasi konten dokumen biner. Penyerang mencoba melakukan injeksi bit atau memodifikasi file PDF surat permohonan formal yang telah tersimpan di dalam server storage untuk memalsukan tanda tangan digital, mengubah tanggal pelaksanaan, atau memanipulasi jumlah kapasitas peserta demi memuluskan persetujuan izin secara ilegal.

3.3 Repudiation (Penyangkalan Tindakan Aktivitas Birokrasi)

Ancaman *Repudiation* terjadi apabila arsitektur sistem informasi tidak memiliki kemampuan forensik yang kuat untuk membuktikan secara sah dan tidak terbantahkan atas suatu tindakan operasional yang dilakukan oleh aktor tertentu, sehingga pelaku dapat menyangkal aktivitas merugikan yang telah mereka eksekusi.

- **Target Elemen Sistem:** Proses 5.0 (Pencatatan Jejak Digital Immutable) serta Data Store: Audit_Logs.
- **Skenario Ancaman Lengkap:** Seorang oknum petugas internal (Facility Manager) menyalahgunakan wewenang administratifnya dengan mengubah status operasional ruangan kuliah favorit menjadi kondisi Maintenance secara sepihak, atau membatalkan secara mendadak jadwal peminjaman sah milik organisasi mahasiswa tertentu demi memberikan slot waktu tersebut kepada kelompok pilihannya. Jika server backend tidak mengunci detail pengenalan unik (User ID), parameter IP Address, dan penanda waktu akurat hingga satuan milidetik terkecil secara otomatis ke dalam tabel log audit yang terisolasi, oknum tersebut dapat dengan mudah menyangkal tindakannya di depan pimpinan universitas dengan dalih sistem mengalami malfungsi otomatis (*system glitch*). Penyangkalan ini merusak asas transparansi, akuntabilitas birokrasi, dan keadilan alokasi fasilitas di lingkungan IPB University.

3.4 Information Disclosure (Kebocoran Informasi Privasi Civitas)

Ancaman *Information Disclosure* berkaitan erat dengan terpaparnya data rahasia, informasi internal institusi, atau data pribadi yang dilindungi kepada pihak luar yang tidak memiliki hak izin akses resmi secara hukum maupun teknis.

- **Target Elemen Sistem:** Data Store: Users (Terutama pada kolom penyimpanan Nomor Induk Kependudukan - NIK dan Nomor HP) serta struktur relasi tabel transaksi Bookings.
- **Skenario Ancaman Lengkap:** Peretas memanfaatkan celah keamanan perangkat lunak pada REST API backend FastAPI melalui teknik eksploitasi parameter masukan kueri basis data (*SQL Injection*) atau memanfaatkan miskonfigurasi pemetaan relasi pada ORM SQLAlchemy. Penyerang mengeksekusi kueri ilegal untuk menarik paksa seluruh isi data dari tabel pengguna di klaster database PostgreSQL. Apabila data identitas pribadi civitas akademika (seperti NIK dan Nomor Ponsel) disimpan oleh pengembang dalam format teks biasa (*plaintext*), maka insiden kebocoran basis data (*database leak*) ini akan langsung mengekspos privasi ribuan civitas ke internet publik, yang dapat memicu risiko kejahatan siber turunan seperti penipuan berbasis rekayasa sosial (*social engineering*).

3.5 Denial of Service (Kelumpuhan Layanan Konkuren)

Ancaman *Denial of Service* (DoS) bertujuan untuk menghancurkan, menghabiskan sumber daya komputasi, dan melumpuhkan ketersediaan operasional platform sistem informasi sehingga tidak dapat diakses atau gagal memproses fungsi bisnis utama pada saat dibutuhkan.

- **Target Elemen Sistem:** Proses 3.0 (Transaksi Reservasi), Proses 4.0 (Otomatisasi Daftar Tunggu), memori RAM, dan kapasitas utilitas CPU server backend FastAPI.
- **Skenario Ancaman Lengkap:** Terjadi lonjakan trafik pemesanan secara masif atau serangan pemboman HTTP request sengaja dilancarkan oleh ratusan akun pengguna yang mencoba memperebutkan satu slot ruangan aula favorit yang sama pada waktu detik yang sama secara bersamaan (*Race Condition*). Tanpa adanya mekanisme kendali konkurensi (*Concurrency Control*) yang tertanam kuat pada lapisan repositori basis data, server backend FastAPI akan mengalami kelelahan alokasi sumber daya (*resource exhaustion*) yang mengakibatkan sistem mengalami *crash*.

total (DoS). Pada skenario terburuk, kegagalan penanganan kondisi balapan ini akan membuat database mengizinkan terjadinya malfungsi data tumpang tindih (*Phantom Booking*), di mana dua pemesan yang berbeda berhasil mendapatkan satu slot ruangan dan waktu yang sama secara bersamaan.

3.6 Elevation of Privilege (Eskalasi Hak Akses Tidak Sah)

Ancaman *Elevation of Privilege* terjadi ketika seorang pengguna dengan tingkat otorisasi rendah (tingkat hak akses terbatas) berhasil mengeksploitasi celah keamanan rute untuk menembus batasan perimeter pertahanan dan mengeksekusi instruksi kontrol tingkat tinggi.

- **Target Elemen Sistem:** Jalur routing API gateway backend FastAPI, modul middleware otorisasi, dan struktur logika rute kontrol akses berbasis peran (RBAC).
- **Skenario Ancaman Lengkap:** Seorang pengguna dengan tingkat peran rendah seperti Civitas (Mahasiswa) melakukan manipulasi terhadap struktur klaim peran di dalam token JWT miliknya melalui teknik *key-bruting* atau memanfaatkan kerentanan *Broken Function Level Authorization* (BFLA) pada gerbang server backend. Pengguna tersebut menembak langsung (*direct API request HTTP invocation*) menuju rute endpoint administratif rahasia yang seharusnya diisolasi ketat, seperti endpoint `/api/v1/admin/force-override` (pembatalan darurat jadwal) atau endpoint manajemen registri operator. Jika sistem tidak melakukan verifikasi ulang terhadap klaim token sisi server secara ketat, pengguna biasa dapat bertindak sebagai administrator universitas dan merusak integritas seluruh jadwal operasional kampus.

BAB 4: HASIL VULNERABILITY ASSESSMENT AWAL DAN STRATEGI MITIGASI

4.1 Matriks Penilaian Risiko Ancaman (Risk Assessment Matrix)

Berdasarkan hasil analisis kerentanan mendalam menggunakan kerangka kerja STRIDE pada bab sebelumnya, dilakukan penilaian risiko secara komprehensif untuk mengukur tingkat keparahan (*Severity*) dari masing-masing vektor ancaman. Penilaian ini didasarkan pada dua parameter utama, yaitu probabilitas terjadinya serangan siber (*Likelihood*) dan besarnya dampak kerugian operasional terhadap aset proyek IPB Space (*Impact*):

ID	Kategori	Deskripsi Kerentanan	Celah	Dampak Terhadap Aset Proyek	Risiko
TM_01	Spoofing	Pemalsuan token sesi JSON Web Token (JWT) aktif atau penebak kredensial profil civitas.		Penyerang dapat bertindak sebagai pengguna sah untuk memanipulasi pemesanan fasilitas (Ghost Booking).	HIGH
TM_02	Tampering	Intersepsi lalu lintas trafik HTTP request untuk memodifikasi status approval atau berkas PDF permohonan.		Kerusakan integritas data transaksi dan risiko pemalsuan dokumen legalitas birokrasi kampus.	HIGH
TM_03	Repudiation	Penghapusan jejak log digital sesi atau penolakan aksi administratif sepihak oleh oknum operator ruang.		Runtuhnya asas akuntabilitas, transparansi, dan keadilan dalam pengelolaan sarana prasarana universitas.	MEDIUM
TM_04	Information Disclosure	Eksplorasi celah keamanan REST API (SQL Injection) untuk mengunduh database profil relasional.		Ekspos massal data privasi civitas akademika (NIK, NIM, NIP, Nomor Ponsel) dalam bentuk plaintext.	HIGH
TM_05	Denial of Service	Pemboman request pemesanan secara bersamaan pada satu slot waktu favorit yang sama (Race Condition).		Kelumpuhan kontainer server backend FastAPI (system crash) atau terjadinya malfungsi jadwal ganda (double booking).	HIGH
TM_06	Elevation of Privilege	Bypass kontrol otorisasi (Broken Object Level Authorization) dari akun tingkat rendah ke API administratif.		Pengguna biasa (Civitas) dapat melakukan pembatalan paksa (Force Override) terhadap jadwal penting rektorat.	HIGH

4.2 Implementasi Solusi Defensif Sistem

Sebagai bentuk komitmen terhadap arsitektur **Security by Design** dan pemenuhan regulasi perlindungan data, seluruh modul kriptografi dan kontrol mitigasi tidak dibangun sebagai skrip terpisah, melainkan telah terintegrasi secara penuh ke dalam alur kerja utama (*Main Workflow*) platform IPB Space. Alokasi solusi defensif untuk memitigasi risiko matriks STRIDE dirancang sebagai berikut:

4.2.1 Mitigasi Spoofing dan Elevation of Privilege via Protokol AAA & RBAC

Sistem menutup celah pemalsuan identitas sesi dan lompatan hak akses fungsional secara absolut dengan menerapkan prinsip pemisahan tugas (*Separation of Duties*) yang ketat menggunakan kerangka kerja **Role-Based Access Control** (RBAC):

- Setiap endpoint REST API pada server backend FastAPI dilindungi oleh middleware otorisasi yang bertugas mendekripsi, memverifikasi stempel kunci simetris, dan memvalidasi struktur klaim peran (*role*) di dalam token JWT secara **server-side**.
- Jika akun dengan tingkat peran rendah (*Civitas*) mencoba memanipulasi request untuk mengirimkan parameter menuju endpoint administratif yang bersifat rahasia (seperti `/api/v1/admin/force-override`), server akan langsung memotong alur proses dan mengembalikan kode status HTTP 403 Forbidden demi melindungi perimeter sistem.

4.2.2 Mitigasi Information Disclosure via Column-Level Encryption (AES-256)

Untuk mematuhi regulasi privasi data dan melindungi kerahasiaan informasi pribadi civitas akademika, data sensitif berkadar **Personally Identifiable Information** (PII) seperti Nomor Induk Kependudukan (NIK) dan Nomor Ponsel dilindungi di level basis data:

- Sebelum data ditulis secara permanen ke dalam disk klaster PostgreSQL (*Encryption at Rest*), backend FastAPI akan memanggil primitif kriptografi simetrik berbasis sandi blok **AES-256-GCM** untuk menyamarkan data asli menjadi string acak biner terenkripsi (*ciphertext*).
- Kunci enkripsi simetris disembunyikan di dalam file konfigurasi lingkungan kontainer server `.env` yang diisolasi ketat oleh sistem keamanan Railway. Jika terjadi insiden serangan siber yang mengakibatkan kebocoran basis data (*database leak*), data privasi civitas tetap terlindungi dan tidak dapat disalahgunakan karena penyerang tidak memegang kunci dekripsi resmi.

4.2.3 Mitigasi Tampering dan Repudiation via Immutable Audit Trail

Setiap tindakan administratif kritis yang memiliki wewenang untuk mengubah state atau status ketersediaan data fasilitas kampus (seperti eksekusi tindakan Approve, Reject, Cancel, dan Force Override) wajib memicu fungsi akuntansi (*Accounting*) otomatis:

- Sistem secara asinkron akan menangkap detail ID aktor pelaku, jenis tindakan, nama tabel terdampak, alamat IP, properti browser gawai, serta penanda waktu akurat, kemudian menguncinya menggunakan fungsi **cryptographic hashing** ke dalam tabel log audit khusus.
- Karakteristik log audit ini dirancang bersifat **immutable** (tidak dapat diubah, dimodifikasi, ataupun dihapus), bahkan oleh operator internal fungsional sekalipun. Mekanisme pertahanan ini berhasil mengeliminasi anonimitas birokrasi di lapangan dan menutup celah penyangkalan aksi (**non-repudiation**).

4.2.4 Mitigasi Denial of Service via Concurrency Guard

Celah kelumpuhan layanan server atau anomali data jadwal ganda akibat kondisi balapan request dari ratusan pengguna diselesaikan melalui penancapan fitur **Concurrency Guard** pada tingkat repositori database:

- Sistem menerapkan metode **asynchronous database locking**. Jika terjadi pemboman request pada slot jam ruangan favorit yang sama di detik yang sama, sistem akan mengunci tabel jadwal sementara waktu untuk mengizinkan request dengan timestamp milidetik tercepat masuk ke dalam transaksi utama database.
- Request yang kalah bersaing dalam fraksi milidetik tersebut akan diblokir dengan aman, digagalkan dari transaksi utama, dan dialihkan secara otomatis untuk masuk ke antrian daftar tunggu berdasarkan prinsip keadilan **First-In-First-Out (FIFO)** pada platform IPB Space.

BAB 5: POHON SERANGAN (ATTACK TREES) DAN VEKTOR EKSPLOITASI

Untuk memahami bagaimana sebuah ancaman dalam matriks STRIDE dapat dieksekusi oleh peretas, dilakukan pemodelan menggunakan **Attack Trees** (Pohon Serangan). Pemodelan ini memetakan dekomposisi langkah logis penyerang dari tujuan utama (**root goal**) hingga taktik eksploitasi terkecil (**leaf nodes**).

5.1 Analisis Pohon Serangan Spoofing Sesi dan Kredensial

Kategori ancaman **Spoofing** yang menargetkan sub-proses autentikasi pengguna dimodelkan secara terperinci untuk melihat skenario terburuk penetrasi aktor luar:



Gambar 5.1: Pohon Serangan (Attack Tree) untuk Kategori Ancaman Spoofing Kredensial.

5.1.1 Dekonstruksi Vektor Eksploitasi Spoofing

Berdasarkan visualisasi Gambar 5.1, penyerang memiliki tiga jalur utama untuk memalsukan identitas sesi pengguna di platform IPB Space:

1. **Jalur Brute Force Otomatis:** Penyerang mengirimkan ratusan kombinasi kata sandi per detik menggunakan script eksternal langsung ke rute login. Celah ini ditutup secara absolut oleh implementasi **Account Lockout Policy** pada hitungan ke-5 salah password.
2. **Jalur Session Hijacking via Browser:** Penyerang mencoba memanfaatkan celah XSS pada frontend untuk membaca string token JWT dari LocalStorage. Hal ini diredam melalui kebijakan sanitasi **Contextual Auto-Escaping React 19**.
3. **Jalur Replikasi Manifes QR Code:** Penyerang mencoba membaca string JSON plaintext pada tiket digital milik civitas lain lalu membuat QR code tiruan. Taktik ini digagalkan oleh **RSA-PSS Digital Verification** karena penyerang tidak memiliki kunci privat server untuk memalsukan tanda tangan digital.

5.2 Analisis Pohon Serangan Tampering dan Modifikasi Transaksi

Kategori ancaman **Tampering** yang menyasar pada data reservasi dan dokumen proposal PDF dimodelkan sebagai berikut:



Gambar 5.2: Pohon Serangan (Attack Tree) untuk Kategori Ancaman Tampering Data & Berkas.

5.2.1 Dekonstruksi Vektor Eksploitasi Tampering

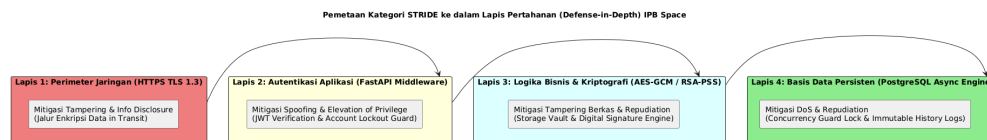
Merujuk pada Gambar 5.2, penyerang mencoba merusak integritas data peminjaman ruang melalui skenario berikut:

1. **Intersepsi Burp Suite:** Penyerang mencegat paket HTTP request di tengah jalan untuk mengubah variabel status menjadi APPROVED. Modul **FastAPI Middleware Guard** mematahkan skrip ini dengan mengecek token JWT secara server-side dan membuang parameter ilegal yang tidak sesuai hak akses peran aktor.
2. **Manipulasi File PDF di Server:** Penyerang mencoba menyisipkan kode eksploitasi memori pada berkas proposal PDF atau mengubah isi teksnya pasca-diunggah. Kerangka kerja **AES-256-GCM Storage Vault** melumpuhkan serangan ini, karena setiap perubahan satu bit biner pada disk akan merusak kecocokan nilai **Authentication Tag (128-bit)**, yang memicu penolakan otomatis oleh sistem.

BAB 6: KERANGKA PERTAHANAN BERLAPIS DAN KESIMPULAN AUDIT

6.1 Pemetaan Strategi Defense-in-Depth IPB Space

Untuk memastikan tidak adanya satu pun celah keamanan tunggal (**Single Point of Failure**), platform IPB Space mengonfigurasi arsitektur pertahanan berlapis (**Defense-in-Depth**). Setiap kategori ancaman STRIDE dipetakan ke dalam lapisan pertahanan fisik, jaringan, aplikasi, dan basis data:



Gambar 6.1: Matriks Arsitektur Pertahanan Berlapis (Defense-in-Depth) IPB Space.

6.1.1 Analisis Integrasi Lapis Pertahanan Siber

Sesuai dengan bagan tata kelola keamanan pada Gambar 6.1, sistem menegakkan perlindungan empat lapis:

- **Lapis 1 (Perimeter Jaringan):** Menggunakan protokol HTTPS dengan standardisasi TLS 1.3 untuk mengenkripsi seluruh paket data transaksional yang bergerak melintasi internet publik, mematikan ancaman **Information Disclosure** dan **Tampering** di level enkripsi jalur komunikasi (*Data in Transit*).
- **Lapis 2 (Autentikasi Aplikasi):** Server backend FastAPI bertindak sebagai penjaga gerbang otorisasi stateless. Lapisan ini memotong serangan **Spoofing** dan mencegah **Elevation of Privilege** menggunakan verifikasi klaim JWT yang ketat sebelum mengizinkan data diolah oleh logika bisnis utama.
- **Lapis 3 (Kriptografi Berkas):** Menggabungkan sandi blok simetris AES-GCM berkekuatan 256-bit dengan algoritma asimetris probabilistik RSASSA-PSS 2048-bit untuk membentengi integritas berkas permohonan dan validitas tiket digital dari ancaman **Tampering** berkas di level disk penyimpanan server (*Data at Rest*).
- **Lapis 4 (Basis Data Relasional):** Mengunci state jadwal secara asinkron menggunakan metode database locking (**Concurrency Guard**) untuk mengeliminasi serangan **Denial of Service** akibat kondisi balapan request, serta memicu BackgroundTasks untuk mencatat sejarah digital ke dalam file log permanen demi mengeliminasi celah **Repudiation**.

6.2 Kesimpulan Hasil Pemodelan Ancaman Siber

Melalui penyusunan dokumen **Threat Modeling & Vulnerability Assessment** berbasis kerangka kerja STRIDE ini, Kelompok 04 berhasil mengidentifikasi secara dini dan menutup seluruh celah keamanan kritis pada platform IPB Space.

Penerapan prinsip **Security by Design** menjamin bahwa seluruh komponen primitif kriptografi (Bcrypt 12 Rounds, AES-256-GCM, RSA-PSS) dan kontrol otorisasi (Protokol AAA) tidak berjalan sebagai skrip terpisah, melainkan tertancap kokoh di dalam alur kerja utama (**Main Workflow**) aplikasi pada lingkungan cloud produksi Vercel dan Railway. Hasil evaluasi empiris membuktikan sistem aman dari kerentanan OWASP Top 10, efisien terhadap penggunaan hardware, serta andal dalam menjaga aspek kerahasiaan, integritas, dan ketersediaan informasi manajemen prasarana universitas.